Lightning talk

LF AI & Data Mini Summit · Oct 19, 2026

Security and Compliance Work Group

Governance and threat modeling for AI-enabled applications

Colin Gigool

IBM · Software Development Engineer

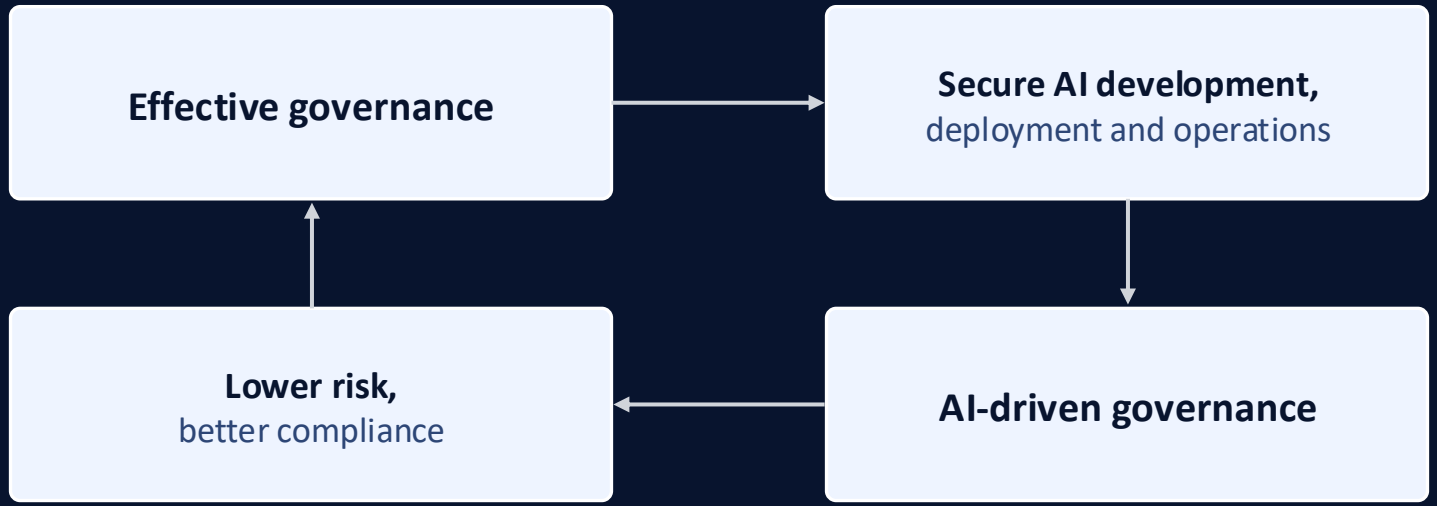
colin.larry.gigool@ibm.com

colin-gigool

The work group

Governance and security, feeding each other

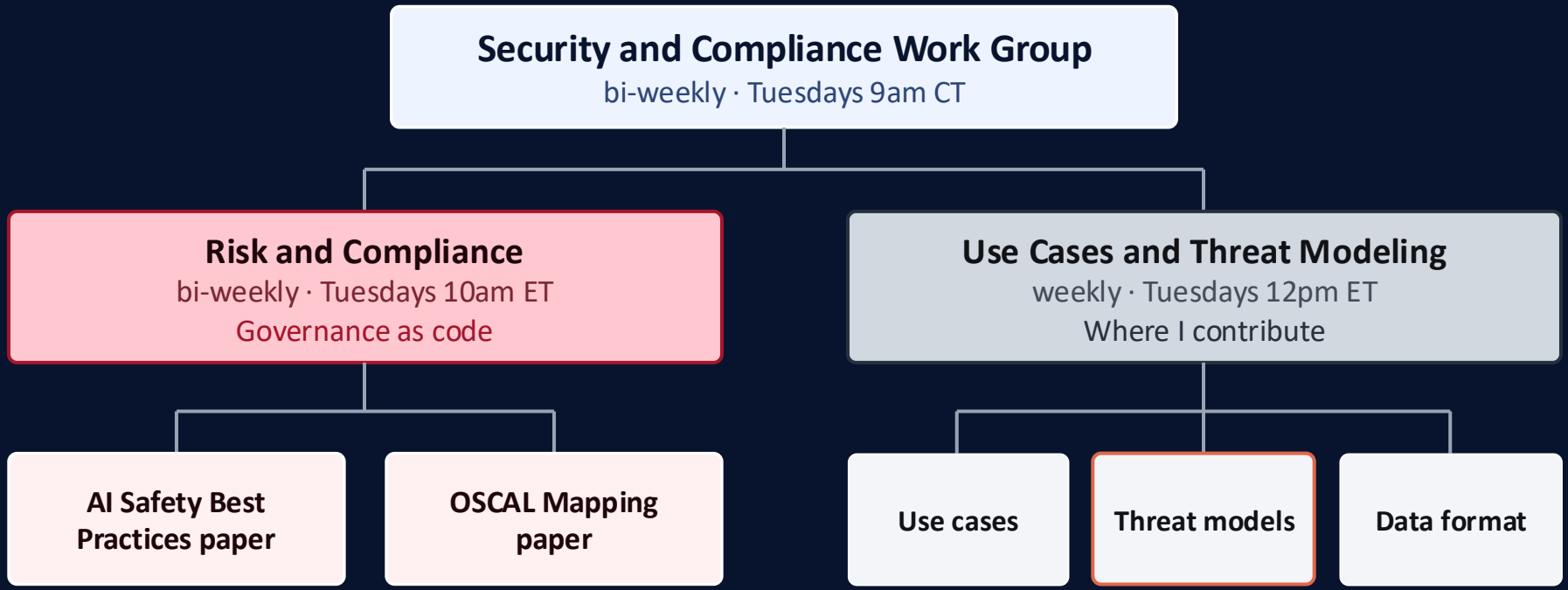
One framework across the AI lifecycle, built on existing projects and standards



Meets bi-weekly · Tuesdays · 9am CT

© 2026 Colin Gigool

The subgroups



Works with OWASP, CycloneDX, SPDX, OpenSSF and NIST

© 2026 Colin Gigool

Subgroup 1 · Risk and Compliance

Compliance as code for AI

Two objectives, built on CNCF compliance and policy projects

Objective 1

Secure AI production governance frameworks

Objective 2

Use AI to enhance organizational process governance

Initiatives · both completed

AI Safety Best Practices for Regulated Environments

OSCAL Mapping Best Practices

Artifacts: use cases, compliance profiles (NIST OSCAL) and risk taxonomies

© 2026 Colin Gigool

Risk and Compliance · white paper v1.0 · June 2026

AI safety for regulated environments

Risk controls mapped across the AI lifecycle and the AI technical stack

Two lenses

AI lifecycle
data collection to agentic orchestration

AI technical stack
infrastructure up to the application layer

Three-phase method

1 · AI risk mapping
map the risks

→

2 · Rule derivation
human in the loop

→

3 · Validation
and automation

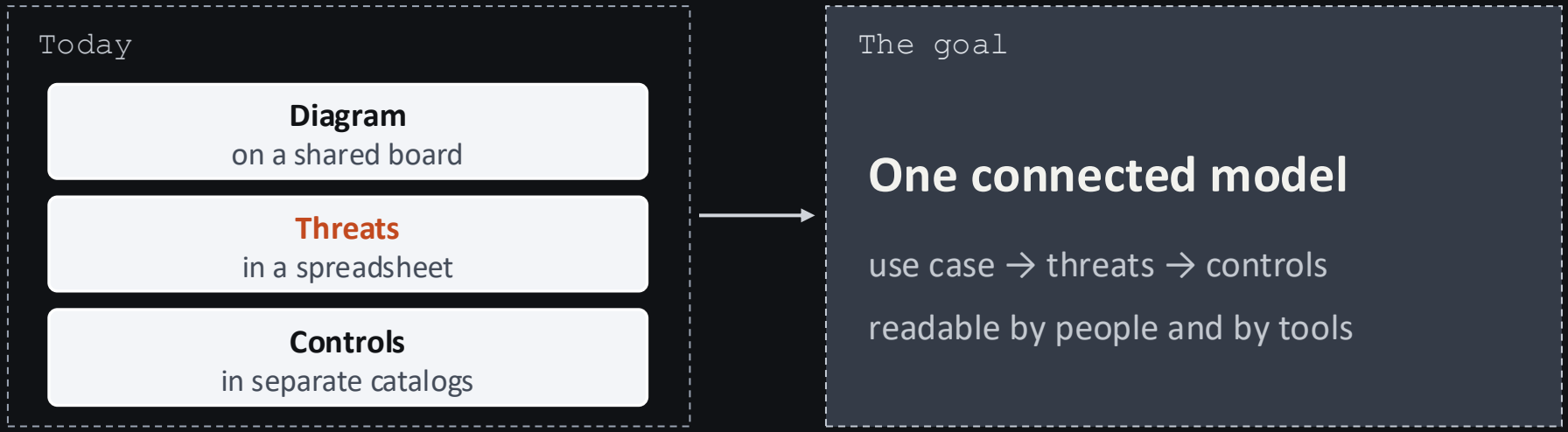
Safety requirements encoded as machine-readable controls in NIST OSCAL

© 2026 Colin Gigool

Subgroup 2 · Use cases and threat modeling

Threat models are written for people to read

Useful to read, but hard to check, link or reuse automatically



© 2026 Colin Gigool

What it is

Interoperable AI security standards, built from real-world threat models

that automated security, compliance and governance workflows can consume

Goal 1

Publish 3 pilot use cases

with threat models, in the OWASP Threat Model Library

Goal 2

Agree one shared workflow

use case → threat model (threats, controls, risks) → standard

© 2026 Colin Gigool

What it does

What the subgroup produces

Use cases

Lifecycle-wide scenarios of how AI is really used

First pilot: AI code assistant

Threat models

Real-world threats per use case, in the OWASP library

Goal: 3 pilots published

Controls

Each threat mapped to NIST 800-53 and CSA AI controls

AI-assisted mapping in progress

Data format

Models as data in CycloneDX 2.0, not just diagrams

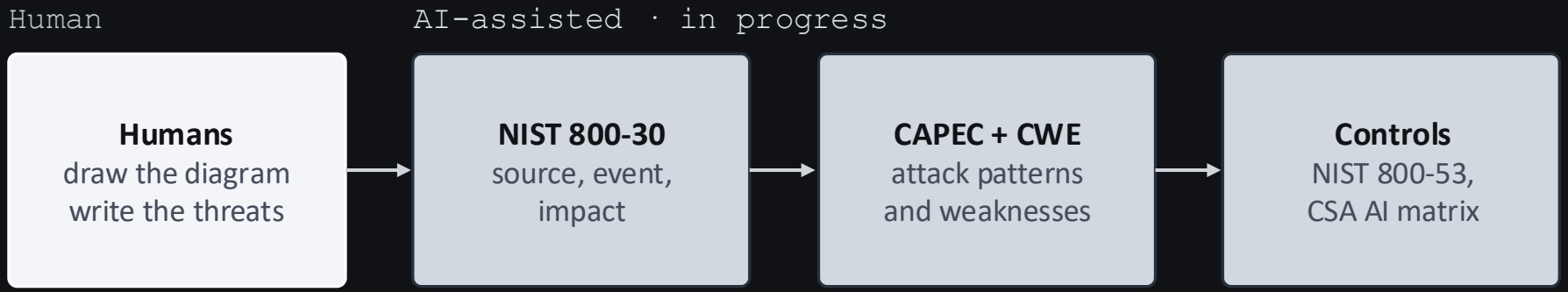
Blueprint: actors, flows, use cases

Built so automated security, compliance and governance workflows can consume it

© 2026 Colin Gigool

How it works

Humans bring judgment. AI does the lookups

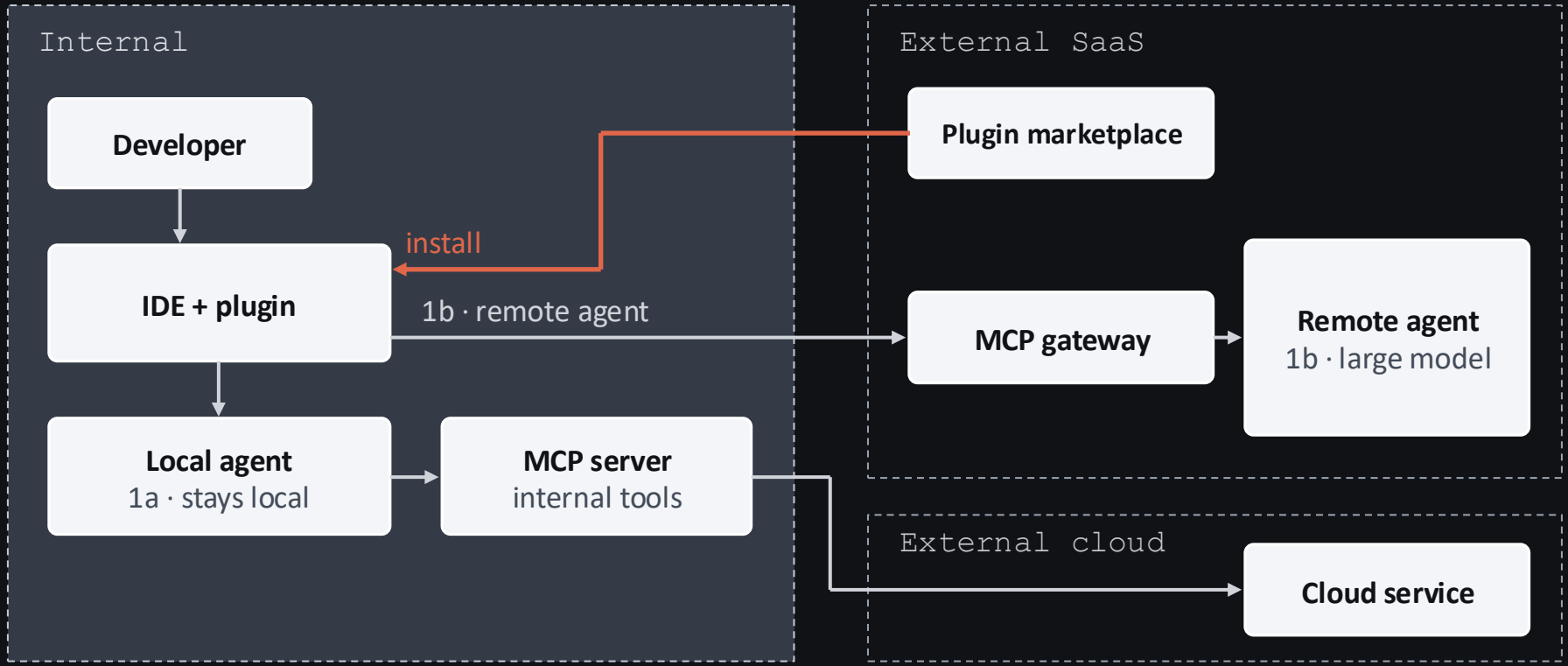


Every threat ends up mapped to concrete controls

© 2026 Colin Gigool

Worked example: AI coding assistant

Run locally (1a) or remotely (1b)



Trust changes at every dashed line

where an attack can enter

© 2026 Colin Gigool

One threat, end to end

Developer uses an unofficial marketplace and unknowingly installs a malicious version of the official plugin into the IDE.

This results in code being sent to an external, attacker-controlled backend.

Enriched by AI with NIST 800-30

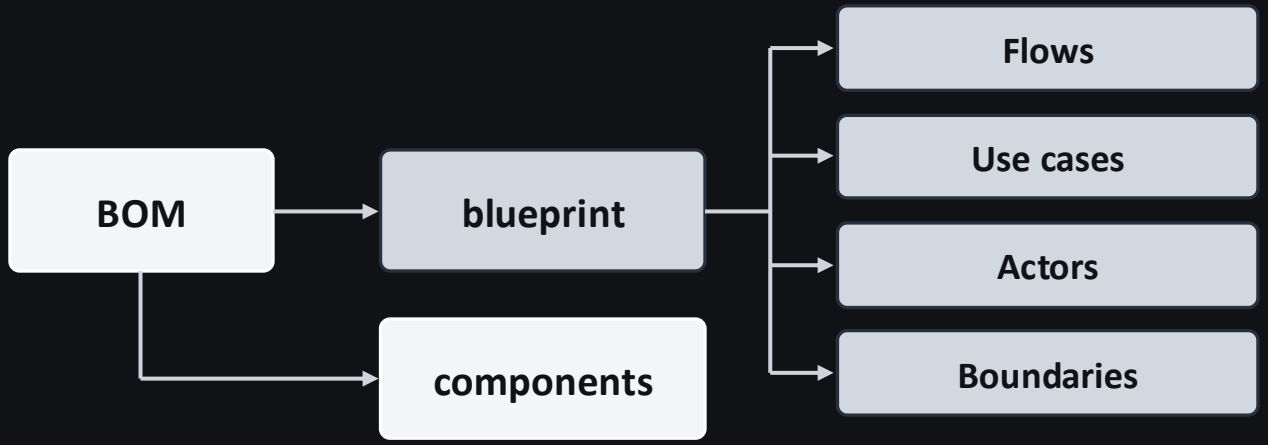
Threat source	Threat event	Adverse impact
Adversarial · individual · insider	**Insert tampered critical components**	**Loss of intellectual property**

Then mapped to CAPEC and CWE, and on to NIST 800-53 and CSA AI controls

© 2026 Colin Gigool

CycloneDX 2.0

Threat models should be data, not diagrams



Use cases group flows, and flows can be reused across use cases

Actors, components and flows each exist within a boundary

One flow, as data: the developer reaching the plugin marketplace

```
"source": "actor:actor-developer",
"destination": "component:external-plugin-marketplace",
```

© 2026 Colin Gigool

CycloneDX 2.0

Because it is data, risk can be assessed

Risk-based assessment from the threat, the component and how components relate



Each component carries its risks in its definition

```
{ "bom-ref": "component:code-asst-plugin",
  "description": "A compromised or malicious AI-powered IDE plugin ...
    risks such as data exfiltration, credential harvesting ..." },
{ "bom-ref": "component:external-plugin-marketplace",
  "description": "An externally operated third-party platform ...
    supply chain risks such as malicious or vulnerable plugins ..." }
```

© 2026 Colin Gigool

Join us

Work group · bi-weekly · Tuesdays 9am CT

Risk and Compliance · bi-weekly · Tuesdays 10am ET

Threat modeling · weekly · Tuesdays 12pm ET

github.com/lfai/security-and-compliance
.../subgroups/risk-and-compliance
.../subgroups/use-cases-and-threat-models

#risk-and-compliance-subgroup
#security-use-cases-and-threat-modeling

Ways to help with threat modeling

Propose the next pilot use case
Review the threat-to-control mappings
Test the AI enrichment



Scan for the repo

© 2026 Colin Gigool